



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



FortiSandbox CVE-2026-39813 CVE-2026-39808 CVE-2026-25089 Exploitation Risk

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-24
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | FortiSandbox CVE-2026-39813 CVE-2026-39808 CVE-2026-25089 Exploitation Risk - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-24 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

FortiSandbox CVE-2026-39813 CVE-2026-39808 CVE-2026-25089

Exploitation Risk

1. Executive Summary

Current reporting highlights exploitation of multiple Fortinet FortiSandbox vulnerabilities affecting unauthenticated API access, path traversal, and command-execution style risk. Because FortiSandbox often handles malware samples and security workflow data, compromise has both system-control and security-visibility implications.

Defenders should treat this as a same-day exposure-management priority because the issue affects security boundary or security infrastructure components that are often reachable from less-trusted networks. This report focuses on verification, containment, detection, and hunt steps that can be actioned without waiting for exploit-code possession.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-39813, CVE-2026-39808, CVE-2026-25089
Product / Component	Fortinet FortiSandbox API / command execution surface
Severity	Critical / high operational priority
Disclosure / update window	May-June 2026 public reporting
Exploitation Status	Check Point weekly intelligence and Help Net Security/runZero coverage describe active exploitation or impacted-asset risk; vendor remediation should be treated as the canonical source for exact version scope.
Primary Defender Question	Which exposed instances remain unpatched or unmitigated, and is there post-exploitation activity?

3. Source Review & Confidence

Daily coverage window note: this automated run prioritized items with high defender value on 2026-06-24 UTC. Where fewer primary reports were available inside the strict 24-72 hour window, the selection window was expanded to recent June 2026 reporting and the uncertainty is reflected in confidence language.

Source	Contribution	Confidence
Primary/vendor or product research	Scope, affected component, and remediation anchor	High
NVD/CVE/CISA-style vulnerability records	CVE identity and vulnerability-management normalization	High
Security research/news corroboration	Exploitation context and defender prioritization	Medium

The assessment is high confidence for defender prioritization because multiple independent sources describe the affected component and exploitation context. Version-specific scoping should still be validated against the vendor advisory before change windows are executed.

4. Vulnerability Details

The reported chain centers on FortiSandbox API weaknesses: path traversal/authentication-bypass behavior and OS command injection can expose sensitive files or execute root-level commands depending on product version and configuration. Treat the appliance as a high-value security-control asset, not as a normal application server.

5. Attack Scenarios

Scenario	Precondition	Defensive Implication
Internet-exposed appliance or portal	Vulnerable service reachable from untrusted networks	Prioritize emergency patching, exposure reduction, and log review.
Internal security workflow compromise	Product is reachable from administrative or security-tooling networks	Treat compromise as a pivot risk because credentials, samples, or security telemetry may be exposed.
Delayed patch with compensating control	Asset is behind allow-listing or VPN	Continue patch validation; hunt for attempted exploitation and anomalous admin activity.

6. Threat Landscape & Exploitation Status

Check Point weekly intelligence and Help Net Security/runZero coverage describe active exploitation or impacted-asset risk; vendor remediation should be treated as the canonical source for exact version scope.. Organizations should assume opportunistic scanning will follow public reporting, especially where assets are internet exposed or fingerprintable.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters
Public management/API surface	Enables unauthenticated or low-friction probing from the internet.
VPN/security gateway edge	Successful bypass can create trusted network access from outside the perimeter.
Security-analysis appliance	A compromised security tool can create blind spots or leak sensitive artifacts.

8. Mitigation and Workarounds

1. Inventory affected products and versions; record owner, internet exposure, and patch state.
2. Apply vendor-fixed versions or documented mitigations; do not rely on obscurity of management URLs.
3. Restrict management/API access to trusted administrative networks.
4. Preserve logs before rebooting or rebuilding systems.
5. Rotate credentials or session material if exploitation is suspected.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Suspicious API or authentication endpoint access	Web/proxy/device logs	Surface exploitation attempts against vulnerable endpoints.

New administrative sessions after anomalous requests	Appliance audit logs / identity logs	Identify successful bypass or session creation.
Unexpected outbound connections from appliance	Network telemetry	Detect post-exploitation callback, tooling download, or data staging.

9.2. Sigma / Detection Rule

```

title: Edge Security Appliance Exploitation Followed By Suspicious Administrative Activity
status: experimental
logsource:
  category: webserver
detection:
  selection_probe:
    cs-uri-query|contains:
      - '../'
      - 'api'
      - 'auth'
      - 'override'
  selection_admin:
    cs-uri-stem|contains:
      - '/api/'
      - '/global-protect/'
      - '/admin'
  condition: selection_probe or selection_admin
fields:
  - src_ip
  - cs-uri-stem
  - cs-uri-query
  - user_agent
level: high

```

9.3. Hunt Query

```

DeviceNetworkEvents
| where Timestamp > ago(14d)
| where RemoteUrl has_any ("/api/", "global-protect", "fortisandbox", "admin")
  or InitiatingProcessCommandLine has_any ("curl", "wget", "python", "powershell")
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Count=count() by DeviceName, RemoteUrl,
RemoteIP, InitiatingProcessFileName
| order by Count desc

```

10. Threat Hunting

10.1. Hunt Hypothesis

If exploitation succeeded, the appliance or adjacent administrative host may show a tight sequence of suspicious endpoint probing, session creation, configuration read/write, and outbound staging.

10.2. Hunt Query

```

DeviceEvents
| where Timestamp > ago(30d)
| where ActionType has_any ("LogonSuccess", "ConfigurationChange", "ServiceInstalled", "FileCreated")
| where AdditionalFields has_any ("api", "admin", "vpn", "sandbox", "auth", "path traversal")
| summarize Events=count(), FirstSeen=min(Timestamp), LastSeen=max(Timestamp) by DeviceName,
ActionType, AccountName
| order by Events desc

```

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Exploitation focuses on remotely reachable

		product interfaces.
T1133	External Remote Services	VPN or edge-service abuse can establish remote access.
T1005	Data from Local System	Security appliance compromise may expose local logs, samples, or configuration.

12. Validation / Lab Testing

No exploit reproduction was performed in this automation run. Validation completed: multi-source source review, exposure modeling, detection drafting, PDF render, text extraction, and publish/upload workflow verification.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Vulnerability Management	Confirm affected versions and patch or mitigate within 24 hours for exposed systems.
High	Network Security	Restrict management/API access and review recent inbound requests.
High	SOC	Run the supplied hunts and preserve logs for suspected exploitation windows.
Medium	IR	Prepare credential/session rotation if anomalous access is confirmed.

14. References

- [1] Check Point 22nd June Threat Intelligence Report — <https://research.checkpoint.com/2026/22nd-june-threat-intelligence-report/>
- [2] Help Net Security: Attackers are exploiting FortiSandbox vulnerabilities — <https://www.helpnetsecurity.com/2026/06/16/fortisandbox-vulnerabilities-cve-2026-39813-cve-2026-39808-cve-2026-25089/>
- [3] runZero: Fortinet FortiSandbox vulnerabilities and impacted assets — <https://www.runzero.com/blog/fortinet-fortisandbox/>
- [4] Fortinet PSIRT advisories landing page — <https://www.fortiguard.com/psirt>